

CO2 AT1

Assessment Report Analysis: Network, Social Engineering & DNS Security

Question 1: Nmap Network Scan Analysis (192.168.1.10) — 20 Marks

1. Report Summary

The Nmap scan against 192.168.1.10 identified three open, service-fingerprinted ports: HTTP (80), SSH (22), and MySQL (3306), along with OS and service-version details. Each open service expands the system's attack surface and, combined with version data, allows an attacker to map the host to known vulnerabilities (CVE matching) without further probing.

2. Security Risks by Service

Port/Service	Risk	Attack Vector
80 / HTTP	Unencrypted traffic; web app vulnerabilities (SQLi, XSS, outdated CMS/server)	Directory brute-forcing, exploiting known web-server/framework CVEs, credential sniffing on unencrypted forms
22 / SSH	Brute-force login, weak/default credentials, outdated SSH daemon with known CVEs	Password spraying, brute-force attacks, exploitation of unpatched SSH versions for RCE
3306 / MySQL	Database exposed to network; weak auth, default root account, unpatched MySQL	Direct remote connection attempts, credential brute-forcing, SQL injection pivoting from the web app to the DB

3. How an Attacker Could Exploit These Services

- Reconnaissance: Version banners (e.g., Apache 2.4.x, OpenSSH 7.x, MySQL 5.7) are matched against public vulnerability databases (NVD/Exploit-DB) to shortlist exploits.
- Web (80): Attacker probes for outdated CMS plugins, injects payloads via forms, or exploits misconfigurations to gain a web shell; unencrypted HTTP also permits credential interception via MITM.
- SSH (22): Automated brute-force/dictionary tools (e.g., Hydra) attempt login; if key-based auth is absent, weak passwords fall quickly. An outdated SSH version may allow authentication bypass or RCE.
- MySQL (3306): If exposed to the internet with default/blank root passwords, an attacker connects directly to dump, modify, or ransom data. Combined with a vulnerable web app, SQL injection can be used to pivot into the database layer.
- Post-exploitation: A foothold on any one service (e.g., web shell) can be used to pivot laterally toward SSH or MySQL, escalate privileges, and establish persistence.

4. Recommended Security Measures

- Patch management: Keep web server, SSH daemon, and MySQL updated to the latest stable, vendor-supported versions to close known CVEs.
- Service hardening: Disable version banners, enforce HTTPS with TLS (redirect HTTP to HTTPS), and disable unused HTTP methods.
- SSH hardening: Disable password authentication in favour of key-based authentication, disable root login, change the default port, enable fail2ban/rate-limiting, and use multi-factor authentication where possible.
- Database security: Bind MySQL to localhost or a private network segment, never expose 3306 directly to the internet, enforce strong unique credentials, and apply the principle of least privilege on DB accounts.
- Network controls: Deploy a firewall/security group to restrict access to management ports (22, 3306) to trusted IP ranges only; use a VPN or bastion host for administrative access.
- Monitoring: Enable logging and intrusion detection (IDS/IPS) to flag brute-force attempts and abnormal connections; conduct periodic vulnerability scans and penetration tests.

Question 2: GoPhish Phishing Campaign Analysis — ABC Technologies Pvt. Ltd. — 20 Marks

1. Report Summary

The simulated phishing campaign showed that 40% of employees clicked the phishing link, 20% entered their login credentials on the fake page, and several employees downloaded a malicious attachment. These figures indicate that a significant portion of the workforce is susceptible to social engineering, and that technical controls alone are insufficient without user awareness.

2. Security Weaknesses Demonstrated by Employees

- Lack of email-verification habits: Employees clicked links without checking sender address, hovering over URLs, or verifying legitimacy — indicating insufficient phishing-recognition training.
- Credential hygiene failure: 20% entering credentials on an external/fake page shows employees do not verify the login page's domain/certificate before submitting sensitive data.
- Unsafe attachment handling: Downloading and likely opening attachments from unsolicited or unexpected emails suggests no habit of scanning attachments or confirming sender intent.
- Low reporting culture: The absence of proactive reporting to IT/security teams shows employees are not engaged as a first line of defence (a 'human firewall').
- Over-trust in internal-looking branding: Phishing templates that mimic internal IT/HR communications succeeded, indicating employees trust visual branding over verifying authenticity.

3. Recommended User Awareness Programs

- Regular, mandatory security-awareness training (quarterly) covering phishing red flags: mismatched sender domains, urgency/fear tactics, suspicious links, and unexpected attachments.
- Simulated phishing exercises on a recurring basis with immediate, non-punitive feedback and micro-training for employees who fail.
- Gamified learning and recognition (leaderboards, rewards for reporting) to build a positive reporting culture.
- Role-based training for high-risk groups such as finance and HR, who are common targets for business email compromise (BEC).

4. Email Security Controls

- Deploy SPF, DKIM, and DMARC to prevent sender-domain spoofing.
- Use an email gateway with anti-phishing/anti-malware scanning, attachment sandboxing, and URL rewriting/click-time protection.
- Enable banners flagging external-origin emails to alert users automatically.
- Provide a one-click 'Report Phishing' button integrated with the security operations team for rapid triage.
- Enforce multi-factor authentication (MFA) so that stolen credentials alone cannot be used to access accounts.

5. Organizational Policies

- Acceptable Use and Email Security Policy clearly outlining safe handling of links/attachments and consequences of non-compliance.
- Incident response procedure for reporting suspected phishing, with defined escalation and containment steps.
- Least-privilege access and network segmentation to limit damage if a credential is compromised.
- Periodic policy review and metrics tracking (click rate, report rate) to measure and demonstrate improvement over time.

Question 3: DNS Zone Transfer (AXFR) Assessment — 10 Marks

1. Report Summary

Using the Dig tool, the assessment found that the organization's DNS server permits an unauthenticated zone transfer (AXFR) to any requester. This exposed internal hostnames, mail server (MX) records, and other DNS records that should normally be restricted to authorized secondary name servers only.

2. Security Implications of the Exposed Information

- Full network mapping: Zone transfer reveals internal and external hostnames (e.g., servers, subdomains such as vpn, admin, dev, test), giving attackers a ready-made map of the organization's infrastructure.
- Targeted attacks: Exposed mail server (MX) records help attackers craft convincing phishing/spoofing campaigns and identify mail infrastructure to attack directly.
- Reconnaissance shortcut: Instead of slow brute-force subdomain enumeration, an attacker instantly obtains a complete list of hosts, drastically reducing reconnaissance time before an intrusion attempt.
- Exposure of internal-only systems: Records for internal-facing servers not meant for public discovery may be revealed, increasing the risk of direct attacks against previously 'hidden' assets.

3. How Attackers Could Exploit These Findings

- Use the harvested hostnames to identify and directly target specific servers (e.g., login portals, VPN gateways, dev/test environments that may be less hardened).
- Correlate hostnames and MX records with other OSINT (e.g., Nmap scans, WHOIS, LinkedIn) to build a full attack profile of the organization.
- Launch spear-phishing or email-spoofing campaigns using accurate mail-server information.
- Identify legacy or forgotten subdomains that may run outdated, vulnerable software, providing an easy initial-access point.

4. Best Practices to Secure DNS Infrastructure

- Restrict zone transfers (AXFR) to explicitly authorized secondary DNS server IP addresses only, using the 'allow-transfer' directive (or equivalent).
- Disable zone transfers entirely on public-facing authoritative servers where secondary DNS is not required, or use TSIG (Transaction Signature) to authenticate transfer requests.
- Segregate internal and external DNS zones (split-horizon DNS) so internal hostnames are never resolvable/exposed externally.
- Regularly audit DNS configurations and run periodic external DNS security assessments (e.g., dig axfr tests) to catch misconfigurations.
- Monitor DNS query/transfer logs for anomalous or unauthorized transfer attempts and alert the security team.